

Monitorización de eventos de seguridad

Ciberinteligencia y Herramientas de Análisis



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

René Serral <rene.serral@upc.edu>

Módulo 1: Introducción a los logs



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

***Casi* Todos los créditos por estas slides van
a:
Manel Roderó**



Para empezar...

Que son estos objetos y qué relación tienen con el curso?



Bitácoras

- Objeto marítimo que ayuda en la colocación de la aguja que siempre apunta al norte
- Cuaderno de bitácora → cuaderno donde se guardaban los registros de los eventos de una embarcación



Bitáctoras

- En el caso de sistemas operativos la **bitácora** es el conjunto de registros que detallan los eventos que han sucedido
- En castellano usamos bitácora para indicar **log** (registro) y **log files** (bitácoras)

```

Terminal
Tue Dec 15 20:49:00 C /var/log/syslog: [system] LOG
Dec 15 19:43:01 Gandalf dbus[974]: [system] Successfully activated service 'org.
Dec 15 19:43:06 Gandalf dbus[974]: [system] Activating service name='org.openus
Dec 15 19:43:06 Gandalf dbus[974]: [system] Successfully activated service 'org.
Dec 15 19:43:07 Gandalf /hpfax: [11830]: error: Failed to create /var/spool/cups
Dec 15 19:43:28 Gandalf python3: io/hpmd/jd.c 93: unable to read device-id
Dec 15 19:43:28 Gandalf python3: io/hpmd/jd.c 875: invalid ip 192.168.1.1
Dec 15 19:43:28 Gandalf /hp-makeuri: hp-makeuri[11858]: error: Device not found
Dec 15 19:44:50 Gandalf dbus[974]: [system] Activating service name='org.openus
Dec 15 19:44:50 Gandalf dbus[974]: [system] Successfully activated service 'org.
Dec 15 19:44:50 Gandalf colord: Profile added: Samsung-ML-2160-Gray..
Dec 15 19:44:50 Gandalf colord: Device added: cups-Samsung-ML-2160
Dec 15 19:46:28 Gandalf kernel: [40146.336194] nouveau E[chrome[2853]] multiple
Dec 15 19:46:28 Gandalf kernel: [40146.336203] nouveau E[chrome[2853]] validate
Dec 15 19:46:28 Gandalf kernel: [40146.336286] nouveau E[chrome[2853]] validate:
Dec 15 19:46:28 Gandalf kernel: [40146.356562] nouveau E[ PGRAPH][0000:02:00:0]
Dec 15 19:46:28 Gandalf kernel: [40146.356573] nouveau E[ PGRAPH][0000:02:00:0]
Dec 15 19:46:28 Gandalf kernel: [40146.356580] nouveau E[ PGRAPH][0000:02:00:0]
Dec 15 19:46:28 Gandalf kernel: [40146.356591] nouveau E[ PFB][0000:02:00:0]
Dec 15 20:17:01 Gandalf CRON[1396]: (root) CMD ( cd / && run-parts --report /
Dec 15 20:20:41 Gandalf kernel: [42199.067003] nouveau E[ PFIFO][0000:02:00:0]

L1887 100% 12W 1?:View Help
restored session from 13 minutes ago; press Ctrl-R to reset session

```

[illegible]

Bitácoras

- Nuestro objetivo es saber “**Qué Sucedió**”
- Como administradores necesitamos saber:
 - Existen registros del sistema?
 - Quién los administra?
 - Cuanto tiempo se guardan los registros?
 - ...
- La bitácora nos proporciona información de qué pasó, entendiendo su contenido podemos evitar futuros eventos similares
 - **Ejemplo:** caja negra de un avión. Permite analizar los eventos en caso de accidente



Bitácoras

- Capturan **eventos** del sistema
 - *Login* de un usuario al sistema
 - Un cambio en una tabla crítica de nuestra aplicación
 - Acceso inválido a nuestro servidor web
 - ...
- A parte para el administrador también son útiles para
 - **Auditorías:** verificaciones para una certificación
 - **Regulaciones:** avales para la organización
 - **Análisis forenses:** análisis post-mortem



Clasificación de eventos

- Un **evento** es cualquier acontecimiento, circunstancia, suceso o caso posible en un sistema
 - *Ejemplo:* fallo en la tarjeta de red del servidor
- Un **evento derivado** consiste en la generación de un nuevo evento como resultado de la aplicación de un método o proceso en función de uno o más eventos anteriores:
 - *Ejemplo:* Alarma por fallo de *ping* (ICMP)
- Un **evento complejo** es un evento que representa una abstracción de otros eventos denominados miembros
 - *Ejemplo:* El servidor web no es accesible

Eventos

- **Log:** registro oficial de eventos obtenidos durante un periodo de tiempo

Tiempo

- Mucha resolución puede saturar el sistema (DoS)
- Poca resolución implica pérdida de datos

Almacenamiento

- Los registros pueden consumir mucho espacio
- Especialmente si se centralizan en un servidor para correlacionarlos

Eventos de seguridad

- Los log necesitan proporcionar **trazabilidad**
- Nos sirven para responder a: **qué, quién, cómo, cuándo**
 - Qué elemento se vió afectado?
 - Quién interactuó con el elemento bajo análisis?
 - Persona, sistema, IP, ...
 - Cuándo sucedió?
 - Cuanto más granular mejor
 - Durante el análisis algo que inicialmente no era relevante puede pasar a serlo
 - Cómo ha sucedido el evento?
 - Una tarea programada ha fallado en la ejecución del proceso



Eventos de seguridad

Feb 13 06:55:26:%SEC_LOGIN-5-LOGIN_SUCCESS:Login Success [user: cisco] [Source: 10.10.1.5] [localport: 23] at 06:55:26 UTC Fri Feb 13 2015



Aug 28 23:57:18 host1 sshd[77716]: Invalid user michelle from 36.137.97.222 port 55446

Aug 30 23:02:27 host1 sshd[77716]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=36.137.97.222 user=root



Event Type: Success Audit Event Source: Security Event Category: Account Logon Event ID: 680 Date: 2015-02-13 Time: 23:53:00 User: NT AUTHORITY\SYSTEM Computer: MYSERVERNAME Description: Logon attempt by: MICROSOFT_AUTHENTICATION_PACKAGE_V1_0 Logon account: Administrator Source Workstation: MYCOMPUTER Error Code: 0x0



Eventos de seguridad

Cuándo

Qué

Quién

Aug 28 23:57:18 host1 sshd[77716]: **Invalid user michelle** from **36.137.97.222** port 55446

Aug 30 23:02:27 host1 sshd[77716]: pam_unix(sshd:auth): authentication failure;
logname= uid=0 euid=0 tty=ssh ruser= rhost=36.137.97.222 user=root



Eventos de seguridad

- Mediante el análisis del registro se pueden detectar eventos como
 - Cambios de configuración fuera del horario laboral
 - Ataques a contraseñas por fuerza bruta
 - Accesos ilegítimos a recursos
 - Escaneo de puertos
 - Fallos en servicios o servidores
 - Envío de spam
 - Propagación de malware
- Mantenimiento de las bitácoras
 - Es crítico clasificarlas
 - Restringir el acceso
 - Centralizarlas para correlacionar eventos

Log Management

- **Log Management (LM)**
 - Tratamiento de grandes volúmenes de mensajes
 - Generados por sistemas y dispositivos
- La administración de estos registros implica
 - Recogida de los registros
 - Agregación y centralización de los registros
 - Retención a medio/largo plazo
 - Análisis de los registros
 - En tiempo real
 - En modo “batch”
 - Búsqueda de registros
 - Presentación de informes



Log Management: Retos

- Análisis inteligente de seguridad (Security Intelligence)
- Agregación y centralización de los registros
- Compliance: cumplimiento de requisitos por la regulación
 - NIST-800.53, PCI-DSS
- Efectividad en los análisis para encontrar el problema
- Seguimiento de eventos y usuarios

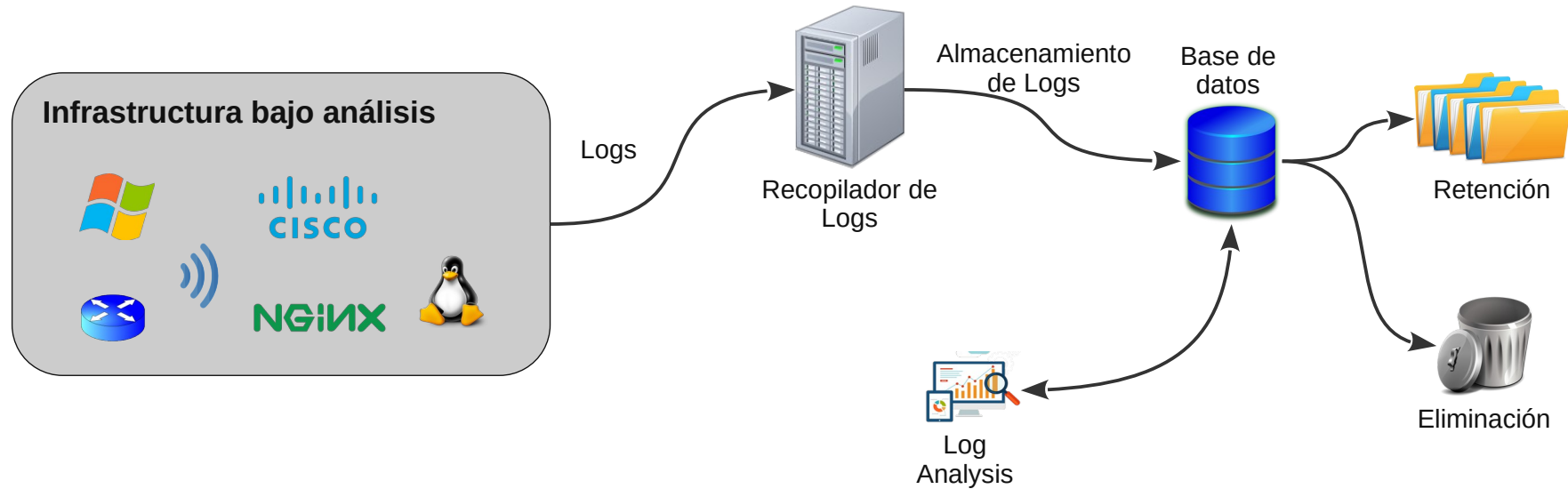


Log Management: Limitaciones

- **Volumen** de los log
 - Modelo distribuido vs modelo centralizado
- **Heterogeneidad del formato**
 - Es necesario unificar el formato para poder correlacionar eventos
- **Complejidad del sistema**
 - Para poder correlacionar y analizar eventos es crítico conocer el entorno donde se analizan



Log Management: Componentes



Log Management: Actores

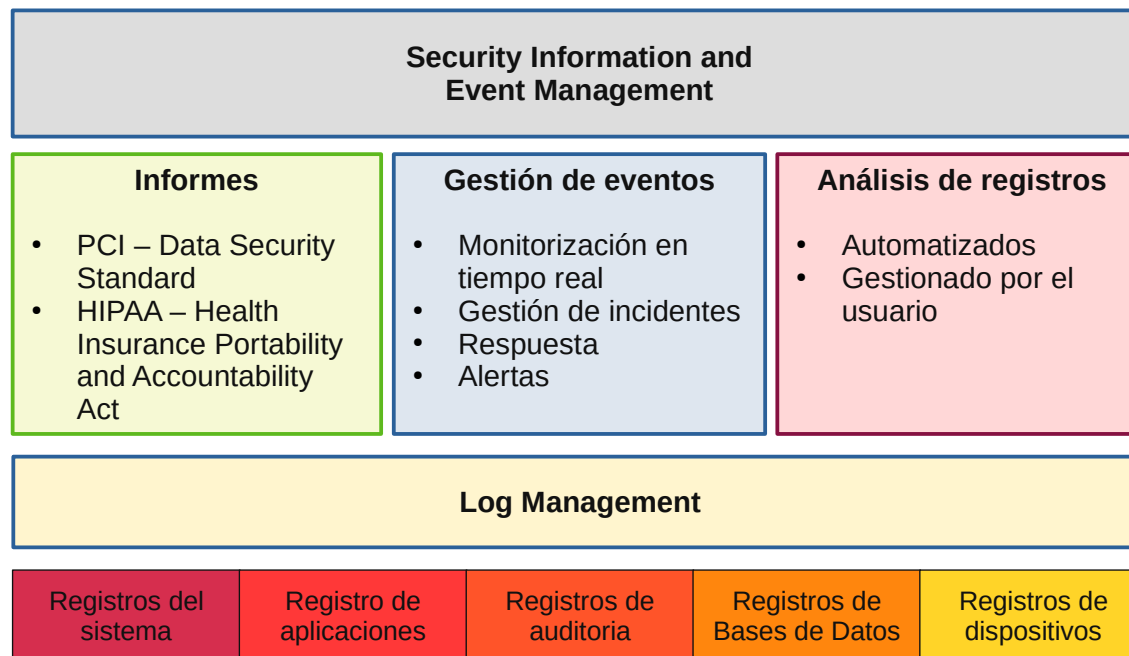
- **Generadores** de Logs
 - Propios del sistema
 - Generalmente todos los procesos generan logs (Heterogeneidad)
 - Detectores complementarios (Monitorización)
- **Centralizadores** de Logs
 - Replicación de archivos: rsync + cron
 - Syslog: rsyslog, syslog-ng...
 - Colectores distribuidos: logstash, fluentd, splunk, ...
 - Servicios de registro remotos: loggly, papertrail, ...
 - SIEM: OSSIM, LogRhythm, ...
 - HIDS/NIDS: OSSEC, Snort, ...



Security Information and Event Management (SIEM)

- Security Information Management (SIM)
 - Sistema de almacenamiento a largo plazo de logs
 - Análisis de datos de registro
 - Generación de informes
- Security Event Management (SEM)
 - Monitorización en tiempo real
 - Correlación de eventos
 - Notificaciones y alertas
 - Dashboards i data visualization
- Los tres términos se usan indistintamente muchas veces

Esquema típico SIEM



Log Management vs SIEM

Funcionalidad	Log Management	SIEM
Recopilación de logs	Recopila todos los logs	Recopila logs relevantes para la seguridad + datos de contexto
Pre-procesado de logs	Indexación, análisis o nada	Análisis, normalización. Categorización, enriquecimiento
Retención de logs	Retiene los datos de registro en bruto	Retiene datos analizados y normalizados
Informes	Informes de uso amplio	Informes enfocados en seguridad
Análisis	Análisis de texto completo, etiquetado	Correlación, puntuación de las amenazas, priorización de eventos
Alertas y Notificaciones	Alertas simples en los log	Informes avanzados enfocados en la seguridad
Otras características	Alta escalabilidad de recopilación y almacenamiento	Gestión de incidentes, análisis de contexto, ...

LM vs SIEM

Log Management

Cuándo

Qué

Quién

Aug 28 23:57:18 host1 sshd[77716]: Invalid user michelle from 36.137.97.222 port 55446



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

LM vs SIEM

SIEM

Hay otros eventos a esta hora? O cerca de esta hora?

Cuál es la dirección IP del sistema? Tiene otros nombres? Donde está la máquina? Quien es el admin? Hay más eventos en la misma máquina?

Quién es este usuario?
De donde proviene?
Existe en el sistema?
Tiene privilegios?

Nombre DNS? Otros nombres?
A qué organización pertenece?
Ubicación geográfica?

Hay otros eventos desde este origen?

Aug 28 23:57:18 host1 sshd[77716]: Invalid user michelle from 36.137.97.222 port 55446

Qué es este servicio?
Que otros mensajes produce? En qué otros servidores se ejecuta?

Aparece en otros log este PID?

Qué es este puerto?
Aparece en otros registros?

